Threat evolution, Q1 2017

GROUP-IB
GLOBAL CYBER SECURITY COMPANY

Table of contents

Introduction 3

Executive Summary: Threats to the Financial Sector, Global 4

Executive Summary: Threats to Financial Sector in Russia and the CIS 5

Executive Summary: Threats to the Government sector 6

Forecasts for Q2 2017 8

Threats to the Financial Sector, Global 9

Targeted attacks 9

Banking threats for PC and Android 10

Attacks on ATM and POS terminals 19

Data leakage 20

Threats to the Financial Sector in Russia 21

Targeted attacks 21

Banking Trojans for PC and Android 21

Attacks on ATMs 25

Data leakage 25

Threats for the Governments 25

APT 25

Hacktivism 27

Deface attacks: Additional Statistics 28

Data leakage 30

Introduction

Every quarter Group-IB releases a report on the development of high tech cyber-crime, featuring new tendencies, emerging trends and predictions on the cyber-threat landscape.

The most dangerous threats have been attacks on the financial sector. This report features threats with a particular focus on the USA, Canada, Europe, Russia and Australia. This document also provides a comprehensive description of threats to governments, including hacktivists' attacks, targeted attacks supported by government and significant data leaks.

To collect data and inform our clients, we analyze various botnets and malware while conducting incident response, monitoring the most secretive underground hacker forums and accumulating information on new trends, threats and data leaks. Every day we research thousands of compromised credentials, bank card numbers, hackers' accounts, messages and announcements on the dark web as well as tens of thousands of attacks, which enables us to promptly notify you of threats targeting your company and clients.

Executive Summary: Threats to the Financial Sector, Global

Targeted attacks

- The Cobalt group has continued active spear-phishing campaigns. Several European banks were sent emails disguised as messages from the European Central Bank.
  Group-IB observed that Cobalt has now begun to attack companies in addition to banks. Compromised servers of large enterprises can be leveraged by the hackers to send out malicious emails. Such an incident was detected in a large Russian IT company named Lanit. We also detected that the criminals sent malicious emails not only to corporate addresses, but also to personal accounts of employees.

  In addition to continued activity, Cobalt has also adjusted their target focus with a confirmed attack against card processing systems (Way4). The criminal group gained access to the card processing system and stole money by removing withdrawal limits. Group-IB specialists expect that they will continue applying similar attack schemes in the future. In Q1 2017 the gang performed spear-phishing attacks in the following countries: Azerbaijan, Russia, Kazakhstan, Ukraine, China, India, Indonesia, Moldavia, Romania, Tajikistan, Turkey, Vietnam, and Western Europe.
- In early 2017 government sites in Poland, Mexico, and Uruguay were compromised with malicious JavaScript files placed to execute third-party code. In the event of successful execution, a remote access Trojan used for spying was installed on the victim's machine. This software is protected by Enigma Protector, a commercial system designed for comprehensive protection of executable files. Banks are known to have been the target of these attacks. The hypothesis is that attackers were conducting espionage on financial institutions, rather than theft of funds. This is confirmed by their tactics and targets that include various national central banks. These attacks are purportedly linked to the Lazarus group, which is related to state-sponsored hackers from North Korea.
- In late 2016, attacks on Ukrainian banks were conducted, allegedly as part of the BlackEnergy operation. In early 2017, several Ukrainian banks suffered successful attacks, which enabled hackers to gain remote access to the banks' network and partly disable its infrastructure. The peak of activity of the Lazarus and BlackEnergy groups targeting banks indicates a growing trend of state-sponsored attacks.
- At least one new group purportedly targeting banks has appeared. Some research companies named the group Fin7, but we assume that these tactics and the Metasploit framework can be used by several groups. To infect target systems, criminals send malicious emails with an attachment containing a PowerShell script. In some attacks, researchers detected the use of Meterpreter, which is a Metasploit framework library for unauthorized covert control. According to security companies, this campaign has already affected 140 banks, government agencies and commercial companies, however, the number of affected banks still remains unverified.

Banking threats for PC and Android

Trojans for Android were used to steal money from the accounts of individuals, while PC Trojans were used both for attacks on individuals and companies. All malicious programs outlined in this section are only targeting non-Russian and former CIS countries:

Trojans for Android:

- A banking Trojan, based on source code published by a user named maza-in, appeared in the Play Market disguised as the legitimate apps "Good Weather" and "World Weather". The malware targets banks in Turkey, Germany, Australia, the UK and the USA.
- Authors of the Honli banking Trojan for Android added web injects for Russian and Australian banks.
- The Tiny.z Android Trojan (other names: Catelites Android Bot, MarsElite Android Bot) has built-in injections for 2249 applications, retrieved from Google Play by parsing for "bank" and "money" keywords. This functionality enables the malware to collect bank card data and credentials from online

banking systems. During the reporting period, the Group-IB specialists observed that the Trojan primarily attacked banks in Russia and the CIS, but we also detected criminals employing the malware to compromise cards banks in Australia, Brazil, Canada, China, Germany, Spain, Sweden, Great Britain, USA and other countries.

- The Android Trojans Marcher and Marcher 2 (Alien bot) were detected to attack banks in Europe and Australia; GM Bot (Mazar) threatens banks in Australia.
- Attacks using Agent.BID Trojans were not detected by Group-IB specialists in Q1.

Trojans for PC

- The most dangerous threat to PC devices is a banking Trojan named Dridex; its new version contains a mechanism for bypassing UAC;
- In Spain, the author of the Vawtrak (Neverquest) banking Trojan was arrested; after that the malware dropped off our radar;
- During the reporting period, Group-IB specialists detected attacks on banks in Europe, the United States, Canada and Australia using the following specialized Trojans: Trickbot, Gootkit, Tinba, Qadars, Zeus, KINS, Qbot, Citadel, Kronos, Ramnit.
- The zBot.ACB (Sphinx2) banking Trojan was tested against Canadian banks, and currently the criminals are believed to be preparing to attack Australian banks.
- The hVNC Trojan source code was leaked online; the malware is developed based on the ISFB banking Trojan, which was earlier offered for sale;
- A Portal of the Zbot malware family was noted to be for sale on underground; the malware is able to collect logs, perform web injections (for all browsers), connect via VNC to a remote host, as well as to download additional files.
- ISFB (aka Gozi / Ursnif) was detected in Australia, Germany, Italy, and Poland and began to spread in Japan.

Attacks on ATM and POS terminals

The major threats for ATMs remain attacks performed by the Cobalt group and Blackbox devices. In addition to that, in Latin America, FireEye specialists discovered a new version of the Ploutus Trojan named Ploutus-D. The malware allows attackers to deplete ATM cash cassettes in minutes.

In Brazil specialists observed attacks on POS terminals employing the banking malware Floki Bot. In Canada and the US a new malicious software for POS terminals dubbed MajikPOS appeared.

Data leakage

In Q1 2017, the following major data leaks were detected:

- A large corporate database, owned by Dun & Bradstreet, containing more than 33 million records has been exposed;
- A credit card breach at some properties of the British-based hospitality giant InterContinental Hotels Group;
- A sharp increase in the number of breaches and thefts of MongoDB databases in order to obtain a ransom.

Executive Summary: Threats to Financial Sector in Russia and the CIS

Targeted attacks

Hackers conduct targeted attacks on banks in order to steal money from correspondent accounts or get access to payment systems, POS terminals and ATMs. In Q1 2017 we saw that the Cobalt group turned their efforts from attacks on ATMs to stealing from card processing systems. Researchers detected a successful attack by

Cobalt on the WAY4 payment system at a Kazakh bank. The criminals managed to gain access with administrator privileges and withdraw money by manipulating credit card transfer limits.

The Buhtrap hacker group is also active, they are currently stealing money from bank customers.
Nine members of the Lurk gang were arrested in several Russian regions.

Banking Trojans for PC and Android

During the reporting period, Group-IB specialists detected attacks on clients of Russian banks using specific Trojans. The vast majority of Trojans for PC were used to deplete accounts of businesses, while mobile Trojans were used to steal money from the accounts of individuals. In Q1 2017, Group-IB specialists observed activity of the following banking Trojans:

- Trojans for PC: ProxyAdder, RTM, Buhtrap, renewed activity of Ranbyus. It is worth noting that ProxyAdder started attacking Kazakh banks.
- The amount of attacks using the Jupiter banking Trojan decreased.
- Web injects and a system to perform automatic manipulations (auto-filler) in the 1C accounting system were added to the RTM Trojan.
- Mobile Trojans: Asacub, Gugi (Limebot), Honli, Opfake, Agent.sx.
- A new modification of the banking Trojan based on the source code published by a user maza-in was detected. This Trojan was distributed under the guise of a Play Market application. Its targets include Russian, Ukrainian, American, Turkish banks.
- The Honli banking Trojan attacks large Russian banks.
- The Tiny.z Android Trojan (aka Catelites Android Bot, MarsElite Android Bot) continued attacking banks of Russia, Ukraine, and Kazakhstan using web fakes. However, the topic offering this bot for sale on an underground forum is currently inactive – the seller has stopped answering questions of potential customers and providing support.
- A criminal group that earlier used Agent.BID has shifted to using Honli malware. At the time of this report, Group-IB specialists have not observed any activity of the Agent.BID Trojan.

Attacks on ATMs

- The Cobalt group continued targeting ATMs.
- Hackers also used other tactics to attack banks – by employing Meterpreter and powershell scripts. However, currently researchers do not have enough evidence to link all known cases to one group. For example, Group-IB experts observed an attack using MoneyTaker malware. FireEye also saw a similar attack and tracked the group as Fin7. At the moment we can say that such tactics and framework can be used by many groups.

Data leakage

During the reporting period, Group-IB specialists detected activity from nine groups of malicious insiders in Russian banks. They continued offering services of confidential bank data sales and remote bank account opening and promoted them on underground platforms.

Executive Summary: Threats to the Government sector

Targeted attacks

Governments are always going to be under the threat of cyber espionage and in some cases suffer attacks on critical infrastructure. Group-IB specialists perform an independent analysis of such threats and are well-informed about the results of global expert studies. In Q1 2017 the following active APT campaigns were detected:

- Lazarus
- BlackEnergy

- Wikileaks CIA Leak
- Shamoon 2
- OilRig
- Nile Phish
- BugDrop
- DragonOK
- Magic Hound

Hacktivism

In Q1 2017, hacktivists conducted over 2,700 attacks on more than 3,200 unique online resources. Over 2,200 attacks detected were “page replacement” (Defacement) and 400 attacks were DDoS attacks (Denial of Service) targeting government, financial, commercial, non-governmental and non-profit organizations. Government websites suffered hacker attacks include those of Thailand, Indonesia, Mexico, Brazil, Italy, Israel, Peru, Argentina, Gabon, Uruguay and Turkey.

Data leakage

During the reporting period, analysts detected the following leaks of government databases:

- WikiLeaks released "Vault 7" dump – it is the “largest ever” publication of confidential documents on the U.S. Central Intelligence Agency. Parts of the Vault 7 document were published on March 7 and March 23, 2017.
- The final portion of information about the Equation Group tools was made openly available.

Forecasts for Q2 2017

Based on the threats detected, we can forecast the following future incidents in Europe, the USA, Australia, Canada:

1) Group-IB specialists expect new state-sponsored APT attacks on banks throughout the world (such as attacks by Lazarus, BlackEnergy);
2) Banks may face thefts from card processing systems by Cobalt.
3) New attacks on ATMs will be performed by Cobalt, Fin7 and probably other groups;
4) After the arrest of the author of the Vawtrak (Neverquest) Trojan in Spain, attacks using this malware have entirely stopped. However, Dridex is expected to fill this gap on the market;
5) The zBot.ACB bank Trojan will start to attack banks in France, the USA and likely other countries, expanding its geography;
6) New modifications of an Android bot based on the source code published by maza-in will appear, disguising as various legitimate apps; the number of thefts will increase respectively;
7) The Honli hacker group may start attacks in Australia;
8) Marcher and Marcher 2 will be used to attack banks in Europe and Australia.
9) Trickbot, Gootkit, Tinba, Qadars, Zeus, KINS, Qbot, Kronos, Ramnit will also be active.

Based on the threats detected, we can forecast the following future incidents in Russia and the CIS:

1) The Cobalt group will perform attacks on bank processing systems, they will probably leverage compromised networks of legitimate companies to perform malicious mailouts;
2) The number of thefts using Buhtrap, RTM, ProxyAdder and Honli malware will increase; RTM is currently targeting accounting software to attack online banking systems;
3) Q2 will see attacks on ATMs and network segments, from which criminals can gain access to ATMs.

Threats to the Financial Sector, Global

Targeted attacks

APT name	Regions attacked	Related notifications	Operation start
Targeted attacks on banks using the Cobalt Strike software	Banks worldwide	CP-1438-9 - CP-1438-16	June 2016

In Q1 2017 numerous spear-phishing campaigns from the Cobalt group and new attack methods were detected.

An attack, which started from malicious emails in September 2016, was detected at a Kazakh bank. As a result, the attackers obtained remote access to the bank's local network and performed continuous reconnaissance and preparation for more than two months. They managed to access the Way4 processing system, changed withdrawal limits for pre-prepared bank cards, and cashed out over 500,000 USD stolen.

Based on aforementioned information, we can conclude that the Cobalt group has chosen a new attack vector by starting attacks on bank processing platforms.

In addition, Cobalt performed malicious mailouts to banks in Russia, Kazakhstan, Kyrgyzstan, and Ukraine acting as legitimate companies Mastercard, Gazprom, and BFS, a company providing ATM-related services; while European banks received infected emails disguised as messages from the European Central Bank.

But the most interesting fact is that the criminals compromised servers of a Russian IT company named Lanit and used them to send a massive number of malicious emails. This campaign affected banks and other companies (insurance and construction companies, news agencies, Internet providers) in Azerbaijan, China, India, Indonesia, Kyrgyzstan, Kazakhstan, Moldova, Romania, Russia, Tajikistan, Turkey and Vietnam.

Like in the case of Lanit, we observe that the hackers are interested to attack not only banks, but also other large companies in order to gain access to their infrastructure and then use compromised networks to send phishing emails.

Exploits used to perform targeted attacks	Regions attacked	Related notifications
Microsoft Word Intruder; Exploits for CVE-2016-0021, CVE-2016-7193 in MS Word; 0day exploits for RCE MSWORD, Ubuntu 16-14 LPE and RedHat-CentOS LPE; Nebula EK; Neptune EK; 0day exploit of iTunes vulnerability for local privilege escalation in Windows x64	Global	CP-1513 CP-1520 CP-1529 CP-1534 CP-1535

To perform targeted attacks, criminals continued using Microsoft Word Intruder exploit packs and, in particular, its exploits for MS Office CVE-2015-2545 and CVE-2015-1641.

It’s interesting to note that during the reporting period, many new offers of various exploits for purchase were detected on underground resources, and lots of them were sold as 0day. Currently we cannot determine if these exploits are real. However, we attribute them as potentially dangerous.

Group-IB specialists detected the following exploits:

- Exploits for CVE-2016-0021, CVE-2016-7193 vulnerabilities in MS Word, allowing the attacker to execute arbitrary code;

- Three 0day exploits sold by one hacker: exploits for RCE MSWORD, Ubuntu 16-14 LPE and RedHat-CentOS LPE. Announcements about sales appeared in late January, in March respective topics were closed, which indicates that buyers were likely found. The seller is not banned on the forum (i.e. if the topics were closed and the seller were banned, this would indicate that the sale was fake);
- In February, an exploit pack named Nebula was offered for purchase; its sale looked suspicious, many forum users thought that this was BEPS EK (purportedly fake malware) sold under a new name, and a little later a seller named Nebula EK was banned. Following this, a similar announcement about sales of Neptune EK appeared, most likely, the author of the announcement was the same hacker. The sale looks suspicious, however, it is interesting that the announcement says about the following exploits packed:
    - CVE-2017-3823 Cisco WebEx Extension
    - CVE-2017-3289 Java Before 7u121 and 8u112 and Java SE Embedded: 8u111
    - CVE-2017-2995 Adobe Flash Player Before v24
    - CVE-2017-0037 Internet Explorer 11
    - Firefox 5-50.0.1 Exploit
    - CVE-2016-7200 & CVE-2016-7201 Edge Exploit
    - CVE-2016-4117
    - CVE-2016-0189 VBScript Engine Internet Explorer 8-11
    - CVE-2016-0034 Microsoft Silverlight before v5
    - CVE-2015-7645 Adobe Flash Player
    - CVE-2015-2419 Internet Explorer 10-11
    - CVE-2014-6332 Internet Explorer 3-11

Due to users' distrust, the seller of this exploit pack was also banned later.

- a 0day exploit for a vulnerability in iTunes for local privilege escalation in Windows x64. This sale also looks suspicious, because the exploit is offered by a user with an old account registered in 2015, which, posted only 2 messages on the forum. Forum users said that it could be a fake sale of an old LPE exploit released by a hacker named luxor2008 in late 2016.

Also, during the reporting period, leading IS vendors reported about vulnerabilities in popular platforms widely used by companies. In late January 2017, Sucuri experts discovered a serious vulnerability in one of the most popular content management systems (CMS) – WordPress. The flaw allows unauthorized attackers to escalate privileges via the WordPress REST API. Vulnerabilities were detected in WordPress 4.7.0 and 4.7.1. In March, a new remote code execution (RCE) vulnerability in Apache Struts2 S2-045 was detected to be exploited in the wild. Exploitation of the vulnerability CVE-2017-5638 enables remote attackers to execute arbitrary commands. The scope of Struts versions affected is rather wide: 2.3.5 - Struts 2.3.31, Struts 2.5 - Struts 2.5.10.

Banking threats for PC and Android

Malware	Regions attacked	Detection
Dridex	Europe	2015

Since early 2017 a new wave of Dridex activity has been observed. The malware is currently targeting banks in the UK and preparing to attack Polish financial institutions. The new version of Trojan has capabilities to bypass UAC (User Account Control) by manipulating recdisc.exe (a Windows default recovery disc executable with advanced administrative privileges), and SPP.dll files.
It is worth reiterating that after the arrest of the author of the Vawtrak Trojan, Dridex has likely become the greatest threat to financial institutions throughout the world.

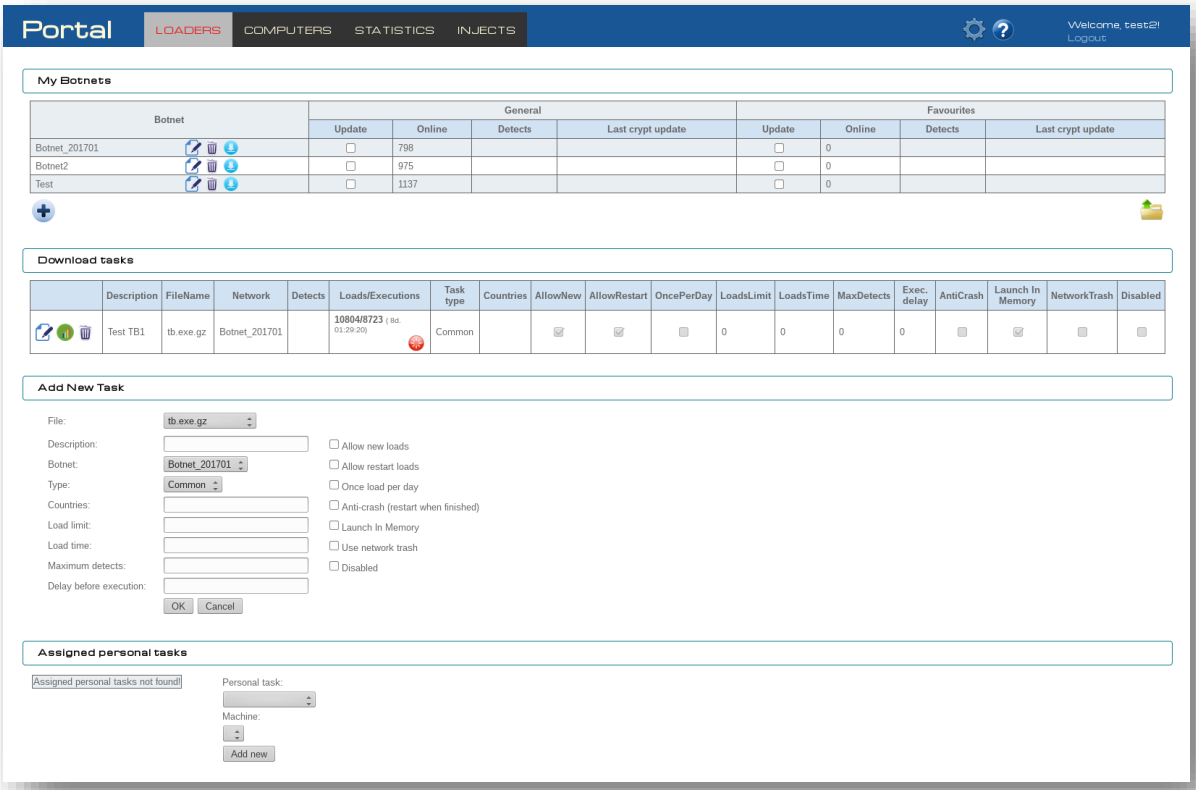
Malware	Regions attacked	Notification	Detection
hVNC	Global	CP-1521	May 2016

In May 2016, a hacker named abs0lem started selling a remote control tool "hVNC" based on the banking Trojan ISFB. Following this, this user was banned on the forum, and the sale and support of the software stopped. In January 2017 the source code of this malware was made public. The malicious program operates on Windows

versions from XP to 10, on all browsers. Publication of this code will likely lead to an increase in the number of modifications to this Trojan.

Malware	Regions attacked	Notification	Detection
Portal	Global	CP-1537	February 2017

Group-IB specialists detected an announcement about the sale of the Portal banking Trojan. It is a Zeus-like bot that is able to collect logs, perform web injections (for all browsers), provide remote access to desktops using VNC, and to download additional files on the infected machine. Group-IB specialists would like to also note specific features of this malware, which is that it operates without copying itself to the disk, which enables the criminal to encrypt only a loader. Also, researchers notice that the bot communicates with its C&C server through its own p2p and Tor. In addition to that, according to the Trojan author, the malware supports web injects for all browsers, though usually they do not operate in Chrome.



Portal control panel

Malware	Regions attacked	Detection
Tiny.z (Catelites Android Bot)	Global	Early 2016

The Trojan has built-in injections for 2249 applications, which are collected by parsing Google Play by keywords “bank” and “money”. The Trojan scans a victim’s device for an applications from the list and displays a versatile window with an app icon and bank name extracted from Google Play. In addition to this universal inject, the malware includes separate injects for banks in Australia, Taiwan, Germany, New Zealand, Singapore, the UK, the US, Turkey.

During Q1 2017, this Trojan was used to attack banks in Russia, Ukraine, Kazakhstan, Australia, Brazil, Canada, China, Germany, Spain, Sweden, the UK, the USA and other countries.

Also, in Q1 researchers observed activity of the following banking Trojans:

Name	Detection	Countries attacked
Marcher	2013	Australia UK Germany France

Examples of attacked banks:

com.barclays.android.barclaysmobilebanking
Nationwide.Mobile
com.IngDirectAndroid
de.adesso.mobile.android.gad
santander.de
com.rbs.mobile.android.natwest
com.caisseepargne.android.mobilebanking
com.isis_papyrus.raiffeisen_pay_eyewdg
net.bnpparibas.mescomptes
fr.creditagricole.androidapp
stgeorge.bank
de.fiducia.smartphone.android.banking.vr
banksa.bank
com.grppl.android.shell.halifax
com.facebook.katana
nab.mobile
com.starfinanz.smob.android.sfinanzstatus
uk.co.tsb.mobilebank
com.starfinanz.smob.android.sbanking
mobi.societegenerale.mobile.lappli
de.dzbank.kartenregie
westpac.bank
comdirect.android
de.consorsbank
com.cacf.MonCACF
fr.axa.monaxa
bankwest.mobile
com.commerzbank.msb
de.dkb.portalapp
fr.lcl.android.customerarea
com.htsu.hsbcpersonalbanking
ingdirect.android
com.grppl.android.shell.CMBlloydsTSB73
de.postbank.finanzassistent
com.boursorama.android.clients
com.ing.diba.mbbr2
de.sparkasse
com.commerzbank.photoTAN
commbank.netbank
uk.co.santander.santanderUK
com.grppl.android.shell.BOS
com.ing.diba.ibbr
com.groupama.toujoursla
com.lbp.peps
com.rbs.mobile.android.ubr
com.whatsapp
application.android
de.adesso.mobile.android.gadfints
com.cic_prod.bad
de.ing_diba.kontostand
com.starfinanz.mobile.android.dkbpushtan
com.lloydsbank.businessmobile
com.cm_prod.bad
com.commerzbank.kontostand
com.fullsix.android.labanquepostale.accountaccess
fr.banquepopulaire.cyberplus
com.db.mm.deutschebank
com.rbs.mobile.android.rbs
businessUK.bb
de.commerzbanking.mobil
com.ing.diba.smartsecure2
fr.lemonway.groupama
com.arkea.android.application.cmso2

Name	Detection	Countries attacked
Marcher 2	2016	Germany UK France Australia Turkey Poland Austria USA

Examples of attacked banks:

vakifbank.mobile
de.adesso.mobile.android.gad
eu.eleader.mobilebanking.raiffeisen
com.finansbank.mobile.cepsube
sparkasse-bochum.de
lloydsbank.co.uk
fr.creditagricole.androidapp
com.isis_papyrus.raiffeisen_pay_eyewdg
at.easybank.mbanking
net.bnpparibas.mescomptes
commbank.com.au1
finansbank.com.tr
com.grppl.android.shell.halifax
pl.bzwbk.bzwbk24
sparkasse-essen.de
akbank.com
com.getingroup.mobilebanking
sparkasse-nuernberg.de
westpac.bank
comarch.mobile

commbank.com.au
com.usaa.mobile.android.usaa
ingdirect.android
easybank.at
ing-diba.at
yapikredi.com.tr
tsb.co.uk
de.ing_diba.kontostand
com.ziraat.ziraatmobil
com.td
com.cm_prod.bad
pl.pkobp.iko
discoverfinancial.mobile
com.bankaustria.android.olb
transferwise.android
fr.lemonway.groupama
com.arkea.android.application.cmso2
postbank.de
ingdirect.com.au
pl.ing.ingmobile
ostsaechsische-sparkasse-dresden.de
sparkasse-dortmund.de
banksa.bank
stgeorge.com.au
coinbase.android
com.starfinanz.smob.android.sfinanzstatus
uk.co.tsb.mobilebank
garanti.com.tr
at.spardat.netbanking
vakifbank.com.tr
mobi.societegenerale.mobile.lappli
sparkasse.at
halifax-online.co.uk
eu.eleader.mobilebanking.pekao
sparkasse-muensterland-ost.de
de.dkb.portalapp
fr.lcl.android.customerarea
com.firstpremier.mypremiercreditcard
com.moneybookers.skrillpayments
com.boursorama.android.clients
com.ing.diba.mbbr2
com.konylabs.cbplpat
nab.com.au
akbank.com.tr
commbank.com.au3
com.garanti.cepsubesi
com.tdbank
com.cic_prod.bad
com.fullsix.android.labanquepostale.accountaccess
de.commerzbanking.mobil
com.IngDirectAndroid
com.ocito.cdn.activity.creditdunord
santander.de
com.caisseepargne.android.mobilebanking
me.doubledutch.rbccapitalmarkets
de.fiducia.smartphone.android.banking.vr
com.suntrust.mobilebanking
sparkasse-koelnbonn.de
commbank.com.au2
com.usb.cps.axol.usbc
com.tmobtech.halkbank
com.starfinanz.smob.android.sbanking
com.cacf.MonCACF
fr.axa.monaxa
bankaustria.at
com.paypal.android.p2pmobile
de.postbank.finanzassistent
banking.co.at
commbank.netbank
frankfurter-sparkasse.de
infonow.bofa
com.paybybank.westernunion
com.akbank.android.apps.akbank_direkt
bnc.android
commbank.com.au4
com.lbp.peps
com.clairmail.fth
fr.banquepopulaire.cyberplus
com.db.mm.deutschebank
ing-diba.de
pl.eurobank
sparkasse-bielefeld.de
sparkasse-wuppertal.de
stgeorge.bank
ecommerce.mobile
sparkasse-hannover.de
nab.mobile
banksa.com.au
at.volksbank.volksbankmobile
pl.bzwbk.mobile.tab.bzwbk24
comdirect.android
fiducia.de
de.consorsbank
bankwest.mobile
sparkasse-duisburg.de
raiffeisen.at
ykb.android
pl.mbank
bankwest.com.au
com.arkea.android.application.cmb
com.grppl.android.shell.CMBlloydsTSB73
bawagpsk.com

com.fi9228.godough
isbank.com.tr
com.wf.wellsfargomobile
halkbank.com.tr
mobile.android
com.pozitron.iscep
com.groupama.toujoursla
com.citi.citimobile
at.bawag.mbanking
application.android
creditkarma.mobile
com.starfinanz.mobile.android.dkbpushtan
ziraatbank.com.tr
berliner-sparkasse.de
wit.android.bcpBankingApp.millenniumPL
sparkasse-leipzig.de
westpac.com.au
commerzbank.de

Name	Detection	Countries attacked
TrickBot	2016	Germany New Zealand Australia

Examples of attacked banks:

postbank.de
secure-banking.de
bv-activebanking.de
anz.co.nz
kskbb.de
stgeorge.com.au
greater.com.au
spk-ts.de
banksa.com.au
flatex.de
berenberg.de
sparkasse.de
stadtsparkasse-hilchenbach.de
sms-hm.de
asb.co.nz
bankofmelbourne.com.au
bankwest.com.au
commbank.com.au
ksk-fds.de
suncorpbank.com.au
s-kukc.de
ospa.de
nab.com.au
anz.com
bankofamerica.com
ksk-tut.de
pnbank.com.au
citibank.com.au
cibc.com
boq.com.au
deutsche-bank.de
qccu.com.au
commerzbank
westpac.com.au
spk-goettingen.de

Name	Detection	Countries attacked
Qadars	2013	UK Australia Belgium Canada Germany Austria Spain Poland

Examples of attacked banks:

hsbc.co.uk
commerzbank.de
lloydsbank.co.uk
desjardins.com
sitebuilder.com
santander.co.uk
citibank.com
grupobbva.com
tandia.com
pcfinancial.ca
ing.nl
smile.co.uk
lacaixa.es
ybonline.co.uk
commbank.com.au
hscunl.ca
noventis.ca
mtlehman.com
paypal.com
bank.pl
norisbank.de
tsb.co.uk
ib.nab.com
firstdirect.com
hald-nor.on.ca
barclaycardus.com
sparda.de
bnc.ca
szn.cz
cbonline.co.uk
implicity.ca
entegra.ca
stgeorge.com.au
bbva.es
sfr.fr
wellsfargo.com
abanca.com
sparkasse.at
halifax-online.co.uk
ing.be
berliner-bank.de
firstcalgary.com
bankofmelbourne.com.au
libero.it
capitalone.com
bancopopular.es
nab.com.au
fidelity.com
bankofamerica.com
metrobankonline.co.uk
targobank.de
suntrust.com
credit-agricole.pl
bancamarch.es
deutsche-bank.de
allegro.pl
barclays.co.uk
o2.pl
memberone.ca
bancopastor.es
tangerine.ca
ingdirect.it
interia.pl
banamex.com
bosbank24.pl
tdbank.com
tescobank.com
ingdirect.es
cybusinessonline.co.uk
caixabank.es
bankaustria.at
bmo.com
chase.com
asmallorange.com
northsave.com
bankia.es
nationwide.co.uk
onet.pl
beaubear.ca
co-operativebank.co.uk
usbank.com
caissepopclare.com
sjpbank.co.uk
td.com
citi.com
citigroup.com
banksa.com.au
gruposantander.es
vancity.com
virgilio.it
arcor.de
53.com
ebank.pl
worldpay.com
kutxabank.es
raiffeisen.at
prospera.ca
comdirect.de
hellobank.be
openbank.es
cibc.com
alice.it
royalbank.com
scotiabank.com
pekaobiznes24.pl
bankofscotland.co.uk
usaa.com
bancsabadell.com
westpac.com.au

Name	Detection	Countries attacked
Gootkit	2014	Germany Canada France Brazil USA

Examples of attacked banks:

postbank
citi.com
td.com
citizensbankonline.com
bnpparibas
desjardins.com
wellsfargo.com
free.fr

tdbank.com
www.sfr.frlogin
capitalone360.com
credit-agricole.fr
53.com
lacaixa.es
santanderconsumerusa.com
capitalone.com
lcl.fr
caixa.gov.br
bankofamerica.com
suntrust.com
cibc.com
bmo.com
comdirect.de
royalbank.com
scotiabank.com
deutsche-bank.de
barclaycardus.com
chase.com
usaa.com
discoverbank.com
commerzbank.de

Name	Detection	Countries attacked
Qbot	2009	USA Netherlands Canada

Examples of attacked banks:

usbank.com
pncbank.com
jpmorgan.com
citigroup.com
wellsfargo.com
tdbank.com
firsttennessee.com
firstcitizensonline.com
53.com
websterbank.com
mandtbank.com
abnamro.nl
frostbank.com
bankofamerica.com
suntrust.com
compassbank.com
capitalonebank.com
scotiabank.com
tcfexpressbusiness.com
firstmeritib.com

Name	Detection	Countries attacked
Tinba	2012	UK Germany Australia Canada Netherlands

Examples of attacked banks:

loydsbank.co.uk
pncbank.com
sparkasse.de
santander.co.uk
tandia.com
deutsche-bank.de
websterbank.com
mandtbank.com
commbank.com.au
hscunl.ca
noventis.ca
mtlehman.com
paypal.com
norisbank.de
tsb.co.uk
huntington.com
hald-nor.on.ca
firstmeritib.com
postbank.de
bnc.ca
bbva
implicity.ca
entegra.ca
wellsfargo.com
americanexpress.com
halifax-online.co.uk
berliner-bank.de
firstcalgary.com
volksbank.de
nab.com.au

anz.com
bankofamerica.com
suntrust.com
omista.com
barclays.co.uk
memberone.ca
tangerine.ca
volksbank.de
tdbank.com
fiducia
bmo.com
desjardins.com
chase.com
northsave.com
nationwide.co.uk
beaubear.ca
co-operativebank.co.uk
td.com
gruposantander.es
vancity.com
abnamro.nl
prospera.ca
cibc.com
compassbank.com
royalbank.com
scotiabank.com
bankofscotland.co.uk
commerzbank
usaa.com
westpac.com.au
hsbc.co.uk

Name	Detection	Countries attacked
Zeus	2007	Italy Spain UK Russia Bulgaria Turkey France Germany

Examples of attacked banks:

dab-bank.com
bancaintesa.it
banif.es
citibank.com
osmp.ru
smile.co.uk
ybonline.co.uk
cajamurcia.es
secservizi.it
paypal.com
gbw2.it
norisbank.de
caja-granada.es
alliance-leicester.co.uk
cajaen.es
popso.it
cbonline.co.uk
bcs.ru
wellsfargo.com
first-direct.com
halifax-online.co.uk
caixatarragona.es
sabadellatlantico.com
ccm.es
hsbc.com
isideonline.it
tdcanadatrust.com
bancopopular.es
gruppocarige.it
anz.com
ebay.com
cajacanarias.es
suntrust.com
cardsonline-consumer.com
nationalcity.com
cajamadridempresas.es
barclays.co.uk
caixaontinyent.es
bancopastor.es
citizensbankonline.com
cajacirculo.es
aib.ie
lloydstsb.com
uno-e.com
procreditbank.bg
iwbank.it
caixalaietana.es
cajalaboral.com
in-biz.it
quiubi.it
citibank.ae
fibancmediolanum.es
caixagirona.es
unicaja.es
chase.com
cajamadrid.es
cajadeavila.es
rupay.com
bancoherrero.com
caixasabadell.net
co-operativebank.co.uk
usbank.com
elmonte.es
banesto.es
nationet.com
banquepopulaire.fr
cajabadajoz.es
gruposantander.es
webmoney.ru
rbsdigital.com
cajavital.es
53.com
cajarioja.es
poste.it
isbank.com.tr
barclays.com
cajasoldirecto.es
bgnetplus.com
openbank.es
bbvanetoffice.com
bancajaproximaempresas.com

lloydstsb.co.uk
citibank.de
hsbc.co.uk

Name	Detection	Countries attacked
ZeusVM (KINS)	2013	UK

Examples of attacked banks:
tsb.co.uk
tescobank.com
lloydsbank.co.uk
citi.eu
halifax-online.co.uk
bankofscotland.co.uk
barclays.co.uk
hsbc.co.uk

Name	Detection	Countries attacked
Atmos	2015	Netherlands Portugal France Canada Germany Italy

Examples of attacked banks:
kasbank.com
snsbank.nl
bnpparibas.net
gilissen.nl
credit-agricole.fr
ing.nl
chasecanada.ca
bpinetempresas.pt
seb.se
fineco.it
activobank7.pt
norisbank.de
novacaixagalicia.es
snsreaal.nl
donner-reuschel.de
postbank.de
regiobank.nl
alex.nl
bancopopular.pt
knab.nl
atbank.nl
montepio.pt
icscards.nl
berliner-bank.de
wuestenrot.de
grupobanif.pt
bancobest.pt
lloydsbankinternational.es
dkb.de
lcl.fr
cgd.pt
crediteurope.nl
targobank.de
cajacanarias.es
deutsche-bank.de
barclays.pt
cajamadridempresas.es
tangerine.ca
mijn-icsbusiness.nl
deutsche-bank.pt
mbna.ca
cristalcard.de
fidor.de
caixalaietana.es
insidecard.de
hsbc.fr
bmo.com
cic.fr
finibanco.pt
td.com
bancamarche.it
banquepopulaire.fr
santanderbank.de
procreditbank.de
cajavital.es
comdirect.de
payangocard.de
labanquepostale.fr
onvista-bank.de
cibc.com
caixapenedes.com
nrwbank.de
royalbank.com
commerzbank.de

Name	Detection	Countries attacked
Kronos	2014	Canada UK USA

Examples of attacked banks:

memberone.ca
beaubear.ca
tangerine.ca
wherewebank.com
bnc.ca
citi.com
td.com
implicity.ca
entegra.ca
tandia.com
vancity.com
prospera.ca
hscunl.ca
noventis.ca
bankofamerica.com
paypal.com
cibc.com
bmo.com
royalbank.com
scotiabank.com
hald-nor.on.ca
desjardins.com
northsave.com
chase.com
omista.com
barclays.co.uk

Name	Detection	Countries attacked
Ramnit	2011	Germany

Examples of attacked banks:
postbank.de
norisbank.de
comdirect.de
sparda.de
deutsche-bank.de
berliner-bank.de
targobank.de
commerzbank.de

Attacks on ATM and POS terminals

- Cash machines are still being targeted by the Cobalt hacker group. Their attacks are aimed at infecting ATM control systems.
- At least one new group purportedly targeting ATMs appeared. Some research companies named the group Fin7, but we assume that these tactics and the Metasploit framework can be used by several groups. To infect target systems, the criminals send malicious emails with an attachment containing a PowerShell script. In some attacks, researchers detected the use of Meterpreter, which is a Metasploit framework library for unauthorized covert control.
- In Latin America, FireEye specialists discovered a new version of the Ploutus Trojan named Ploutus-D. The malware allows attackers to deplete ATM cash cassettes in minutes. That said, a money mule needs to have a master key to open the top portion of the ATM, a physical keyboard to connect to the machine, and an activation code (generated by attackers) in order to dispense money from the ATM. The speed in which the operation is carried out minimizes the risk to be detected by bank security services.

  Researchers note the following Ploutus-D specific features: it attacks Kalignite ATM platforms, and can be launched on ATMs with Windows 10, Windows 8, Windows 7, Windows XP; the

malware is currently configured to work with Diebold ATMs, but it can potentially be adjusted to attack ATMs by other manufacturers

- Researchers identified attacks on POS terminals using FlokiBot in Brazil. It is interesting because FlokiBot is not a POS Trojan, but in the detected attacks it was used to get Track2 card dumps from infected POS terminals.
- In January 2017, researchers uncovered a new breed of POS Trojans: MajikPOS, affecting businesses across North America. According to security specialists, MajikPOS's operators use a combination of PoS malware and remote access Trojans (RATs) to attack their targets. All stolen data is sold by hackers in specialized stores (card shops) hiding under a nickname MagicDumps.

Data leakage

- In March, it was reported about a Dun & Bradstreet database large-scale leakage. This leak contains 33 million records on government organizations and large businesses. The database is quite diverse, including personal and work email addresses of employees, phone numbers, titles, responsibilities, number of employees in organizations, etc. This database was collected in order to sell its parts to marketing agencies.
- InterContinental Hotels Group (IHG), the British-based parent company for more than 5,000 hotels worldwide including Holiday Inn, informed it has been investigating claims of a possible credit card breach at some U.S. locations since January 2017.
- Security researchers reported a massive growth in the number of MongoDB databases hijacked and held for ransom. Specialists informed about around 30,000 victims attacked by more than a dozen hacker groups. The problem results from companies that have used the default installation configuration for MongoDB, which does not require authentication to access the database.

Threats to the Financial Sector in Russia

Targeted attacks

APT name	Regions attacked	Related notifications	Operation start
Targeted attacks on banks using the Cobalt Strike software	Banks worldwide	CP-1438-9 - CP-1438-16	June 2016

An attack, which started from malicious emails in September 2016, was detected at a Kazakh bank. As a result, the attackers obtained remote access to the bank's local network and performed continuous reconnaissance and preparation for more than two months. They managed to access the Way4 processing system, changed withdrawal limits for pre-prepared bank cards, and cashed out over 500,000 USD. Based on the abovementioned information, we conclude that the Cobalt group has chosen a new attack vector by starting attacks on bank processing platforms.

In addition, Cobalt performed malicious mailouts to banks in Russia, Kazakhstan, Kyrgyzstan, and Ukraine acting as legitimate companies Mastercard, Gazprom, and BFS, a company providing ATM-related services; while European banks received infected emails disguised as messages from the European Central Bank.

The most interesting fact is that the criminals compromised servers of a Russian IT company named Lanit and used it to send a massive number of malicious emails. This campaign affected banks and other companies (insurance and construction companies, news agencies, Internet providers) in Azerbaijan, China, India, Indonesia, Kyrgyzstan, Kazakhstan, Moldova, Romania, Russia, Tajikistan, Turkey and Vietnam.

Like in the case of Lanit, we observe that the hackers are interested to attack not only banks, but also other large companies in order to gain access to their infrastructure and then use the compromised networks to send phishing emails.

Banking Trojans for PC and Android

Malware name	Regions attacked	Detection	Notification
Android.Banker based on source code published by “Maza-In”	Russia, Ukraine, the USA, Turkey, Germany, Australia, the UK	2017	CP-1512 CP-1527

Group-IB specialists analyzed a sample of an Android banking bot based on the source code published by a user named maza-in in late 2016. This banking Trojan has the functionality to obtain administrator privileges, intercept SMS messages, perform web injections, and hide its activity.

This Trojan distributed under the guise of a Play Market app is targeting top-tier Russian banks, as well as banks of the Ukraine, the USA, and Turkey.

Researchers also uncovered another modification of this Trojan which was placed in the Play Market masked as "Good Weather" and "World Weather" applications. It is targeting banks in Turkey, Germany, Australia, the UK, and the USA.

Malware name	Regions attacked	Detection	Notification
Honli	Russia	2015	CG-1514

The Honli hacker group has been active since 2015, specializing in infecting Android devices with their Trojan to steal bank card and online banking authentication data from victims. At the end of 2016, researchers detected

that in order to obtain credentials on the infected device, the criminal group used fake pages displayed on top of legitimate apps, including those created for Russian banks VTB24, Tinkoff Bank, Alfa-Bank, and Sberbank.

Threat name	Regions attacked	Detection
Asacub	Russia	2016

In Q1 2017 specialists observed activity of hacker groups using an Android Trojan Asacub to attack Russian banks, such as Sberbank, Alfa-Bank, Tinkoff Bank, as well as the following payments systems: QIWI Wallet, iMTCPay, MOBI.Dengi. The malware has capabilities to steal user data (such as SMS messages, bank card data, device location), display a phishing dialogue box on the top of official applications, and delete all APK files (uninstall all applications) on the device.

Threat name	Detection	Regions attacked
ProxyAdder	Russia, Kazakhstan	2016

The malware is able to modify system settings to forward user requests to the banks' websites to the proxy server, created by the attacker. This enables the attacker to intercept all requests between the user and the bank, while an unsuspicious user sees a phishing page instead of the legitimate online banking page. To modify system settings, attackers use a proxy auto-config (PAC) file that automatically adds changes to the attacked browsers to redirect web requests to a specific proxy server.

Based on analysis of recently detected samples, the criminals are currently targeting the following banks: Sberbank, VTB24, Alfabank, Kazkommertsbank, Halyk Bank.

Threat name	Detection	Regions attacked
RTM	December 2015	Russia

The Trojan is designed to attack online banking and payment systems. The modules extending the basic program functionality are allegedly designed for both 32-bit systems and 64-bit systems.

The targets include:

- QiwiCashier
- ClBank
- WinPost
- SberBank_Fiz
- HandyBank
- Raiffeisen
- VTB24
- BiCrypt
- iBank2
- Interbank
- Inversion
- INIST
- SberBank_BO
- RosBank
- Inter Pro
- Faktura
- iBank2_PC
- BSS_PC
- SberBank_PC

Specialists detected that the authors added web injects and an auto-filler for the 1C accounting system to the malware.

Threat name	Detection	Regions attacked
Buhtrap	2014	Russia

Buhtrap malware is designed to collect authentication data, search for specific online banking apps and processes as well as to replace payment details. Currently the group is targeting bank clients.

Threat name	Detection	Regions attacked
Ranbyus	2012	Russia

Ranbyus is a banking Trojan targeting online banking and payment systems. Its specific feature is absence of web injects that are usually employed in such attacks. Instead the malware conducts attacks on specific banking software. Ranbyus changes Java code in specific applications without modifying JVM (Java virtual machine).

Threat name	Detection	Regions attacked
Agent.sx	2015	Russia

Criminals use this banking bot, which has capabilities to send and intercept SMS messages, to perform unauthorized money transfers through SMS banking. Developers have added an auto-reply function to the malware control panel, which enables attackers to send messages with transfer confirmation automatically. The program also has the functionality to parse SMS messages in order to obtain victim's card balance. This parser can be customized for any bank. The Trojan also has capabilities to collect bank card data using a Google play phishing dialog.

Malware name	Regions attacked	Detection
Asacub	Russia	2016

In Q1 specialists observed activity of hacker groups using an Android Trojan Asacub to attack Russian banks, such as Sberbank, Alfa-Bank, Tinkoff Bank, as well as the following payments systems: QIWI Wallet, iMTCPay, MOBI.Dengi.

The malware has capabilities to steal user data (such as SMS messages, bank card data, device location), display a phishing dialogue box on the top of official applications, and delete all APK files (uninstall all applications) on the device.

Threat name	Detection	Regions attacked
Gugi/Limebot	August 2016	Russia

The Trojan displays a phishing dialog box on the top of official applications in order to steal online banking credentials and credit card data. In addition to that, the malware is able to capture SMS messages and contact lists, run USSD requests and send SMS on command from the C&C server. In Q1 2017 Gugi/Limebot attacked the following Russian banks: Raiffeisen Bank Russia, SberBank, Tinkoff Bank, VTB24, Alfa Bank. The Trojan spreads via SMS spamming and uses fake windows to capture data.

Malware name	Regions attacked	Detection
Opfake	Russia	2015

The Trojan is designed to steal money through SMS banking services and display phishing windows to capture bank card data. After reboot the program continues its operation.

Malware name	Regions attacked	Detection
Tiny.z (Catelites Android Bot)	All countries	Early 2016

The Trojan contains injects for 2,249 applications, which were collected by parsing Google Play by keywords “bank” and “money”. The Trojan scans a victim’s device for an application from the list and displays a versatile window with an app icon and bank name extracted from Google Play. In addition to this universal inject, the malware includes separate injects for banks in Australia, Taiwan, Germany, New Zealand, Singapore, the UK, the US, Turkey.

Group-IB specialists detected that in Q1 2017 this Trojan was used to attack banks in Australia, Brazil, Canada, China, Germany, Spain, Sweden, the UK, the USA, Kazakhstan, Ukraine, Russia, and other countries.

Attacks on ATMs

Despite the fact that Cobalt has turned their efforts to stealing from card processing systems, the group is expected to continue attacking ATMs.

Data leakage

During the reporting period Group-IB specialists detected 9 incidents of providing/selling/searching for confidential bank data related to Russian banks on underground resources. Insiders in banks are believed to be involved in these incidents. Group-IB specialists detected the following services offered on dark web:

- Sales of clients' databases;
- Sales of information about bank accounts;
- A service of unblocking frozen accounts.

Threats for the Governments

APT

APT name	Regions attacked	Operation start
Lazarus	Poland, Mexico, Uruguay	October 2016

In late 2016 - early 2017 researchers uncovered attacks purportedly linked to the North Korean hacker group Lazarus. Recently they conducted watering-hole attacks on several Polish banks leveraging a compromised website of the Polish Financial Supervision Authority (knf.gov.pl). They modified website code so that malicious files written in JavaScript were downloaded on the victim's computer. Execution of these malicious files activated loading the malware protected by a commercial packer called Enigma Protector.

APT name	Regions attacked	Operation start
BlackEnergy	Ukraine	2015

In late 2016, a massive hacker attack on Ukrainian banks was conducted purportedly as part of the BlackEnergy campaign. In early 2017, several Ukrainian banks were also successfully attacked. As a result, the attackers managed to remotely access the bank's network and partly disable its infrastructure.

APT name	Regions attacked	Operation start
WikiLeaks' CIA Document Dump	USA	2017

On March 7, 2017 WikiLeaks started publishing a series of documents code-named Vault 7, which are believed to have been obtained as a result of the 'largest ever' leak in the US Central Intelligence Agency (CIA). These dumps detail activities and capabilities of the CIA to perform electronic surveillance and cyber warfare.

WikiLeaks claimed that the files had "circulated among former U.S. government hackers and contractors in an unauthorized manner, one of whom has provided WikiLeaks with portions of the archive". The first batch of documents named "Year Zero" consists of 8,761 documents and files, purportedly from an isolated, high-security network situated inside the CIA's Center for Cyber Intelligence.

The second batch of documents, published on March 23 under the title Dark Matter, reveals exploits that the CIA created to infect Apple devices (Mac, iPhone) with sustainable malware. In addition to that, these documents outline other techniques to attack MacOS devices.

APT name	Regions attacked	Operation start
Shamoon 2	Middle East, Saudi Arabia	November 2016

Shamoon 2 is a malware family that has been used in attacks on several targets in the Middle East since November 2016. In total, three waves of attacks were tracked: on November 17, 2016, November 29, 2016 and January 23, 2017 respectively. This malware family is developed based on the Shamoon malicious program, which was used in attacks on a Qatar company "RasGas" and "Saudi Aramco", a company located in Saudi Arabia, in 2012. The malware was distributed using spear phishing emails with a Microsoft Office document attached. After the user opened the attachment, PowerShell commands were immediately executed.

APT name	Regions attacked	Operation start
OilRig	Middle East, Israel	2015

Attacks from the OilRig group were recorded for the first time in late 2015. As part of their recent campaign, the group sent phishing emails acting as authentic IT vendors, tricking the victim into installing an official VPN client software by Juniper, which was combined with the Helminth malware. The malware sample was signed by a legitimate digital certificate issued by Symantec to the AI Squared company, which was stolen by the criminals.

APT name	Regions attacked	Operation start
Nile Phish	Egypt	November 2016

A large-scale phishing campaign Nile Phish targeting Egyptian NGOs has been active since late November 2016.

To send phishing emails the attackers use gophish, an open-source phishing framework written in the Go language. The gophish framework is intended to be used defensively, as part of anti-phishing trainings. Its developer describes it as "designed for businesses and penetration testers.

APT name	Regions attacked	Operation start
BugDrop	Ukraine, Russia, Saudi Arabia, Australia	January 2017

BugDrop is a hacker campaign targeting 70 different organizations located in Ukraine, Russia, Saudi Arabia and Australia. As part of the campaign, the attackers capture information about the victims, including audio records from microphones of infected computers. To collect data, the attackers use the Dropbox cloud service. The malware is distributed using spear phishing emails with Microsoft Office attachments containing malicious macros.

APT name	Regions attacked	Operation start
DragonOK	Japan, Taiwan, Tibet, Russia	April 2015

The DragonOK group was originally discovered in April 2015 during their attacks on various organizations in Japan. At the time of this report, their target list has expanded to Taiwan, Tibet and Russia. To conduct attacks, the group uses the following malware families: Sysget, IsSpace, and TidePool. The malware is delivered both directly via phishing emails, as well as in Rich Text Format (RTF) documents exploiting the CVE-2015-1641 vulnerability.

The content of infected document is specifically designed for certain targets, for example, to attack victims in Russia, the hackers used a Russian language decoy document, which outlined a vulnerability of the Russian cryptographic algorithm GOST 28147-89 to differential cryptanalysis.

APT name	Regions attacked	Operation start

Magic Hound	Saudi Arabia	2016

Magic Hound is a campaign targeting government, energy and technology organizations located in Saudi Arabia and companies with business interests in this region. To conduct attacks, the hackers employ Microsoft Word and Excel documents with built-in malicious macros that run PowerShell commands in order to install additional programs on the victim's computer, such as malicious executables or Pupy remote access tool written in Python. To distribute malicious documents, attackers placed them on hacked legitimate resources and sent phishing emails containing links to these documents.

Hacktivism

In Q1 2017, hacktivists conducted over 2,700 attacks on more than 3,200 various online resources. Over 2,200 attacks detected were of the "page replacement" type (Defacement) and 400 attacks were DDoS attacks (Denial of Service) targeting government, financial, commercial, non-governmental and non-profit organizations. Government websites suffered hacker attacks include those of Thailand, Indonesia, Mexico, Brazil, Italy, Israel, Peru, Argentina, Gabon, Uruguay, Turkey and others.

The table below contains information on the major hacktivists' operations conducted in Q1 2017.

Operation name	**Regions attacked**	**Operation start**	**Types of attacks during the operation**
OpSingleGateway	Thailand	22.10.2015	DDoS, Deface, Data leakage
	Description: this Anonymous campaign targets Thailand government websites. The operation was originally launched when the Thai government started working on a bill that would force the country's entire Internet traffic through one single gateway. The centralized gateway would give the government the ability to control, intercept and arrest any person not complying with new Internet laws.		
OpSeaWorld, OpWorldAnimal, OpKillingBay	North America, Northern Europe, Southeast Asia		DDoS
	Description: OpBEAST, OpWhales and OpKillingBay operations were started by various hacker groups in order to attract public attention to animal protection issues. Originally they had targeted websites of entertainment theme parks, water parks and zoos to have further focused their attention on resources belonging to seafood suppliers and technology conglomerates which were considered to damage ecology. Currently, the hacktivists target websites of Japanese financial and government organizations, Norwegian government organizations, Icelandic seafood restaurants, and government organizations in Texas, the USA.		
OpISIS	ISIS, Middle East, Islamic organizations worldwide	11.08.2014	DDoS
	Description: during the OpISIS operation hackers attacked websites related to terrorism as well as religious and information Islamic websites and media resources.		
OpIsrael	Western Asia	07.04.2013	DDoS, Deface, Data leakage
	OpIsrael is an annual operation against Israeli websites and online resources. During the operation hacktivist groups attack government, educational,		

	banking and non-governmental resources and media portals. The operation starts on April 7th every year.

Deface attacks: Additional Statistics

Group-IB specialists have summarized statistics of hacked websites (deface attacks), which is presented in charts below.

Chart 1 provides the breakdown of attacked resources by web servers used.

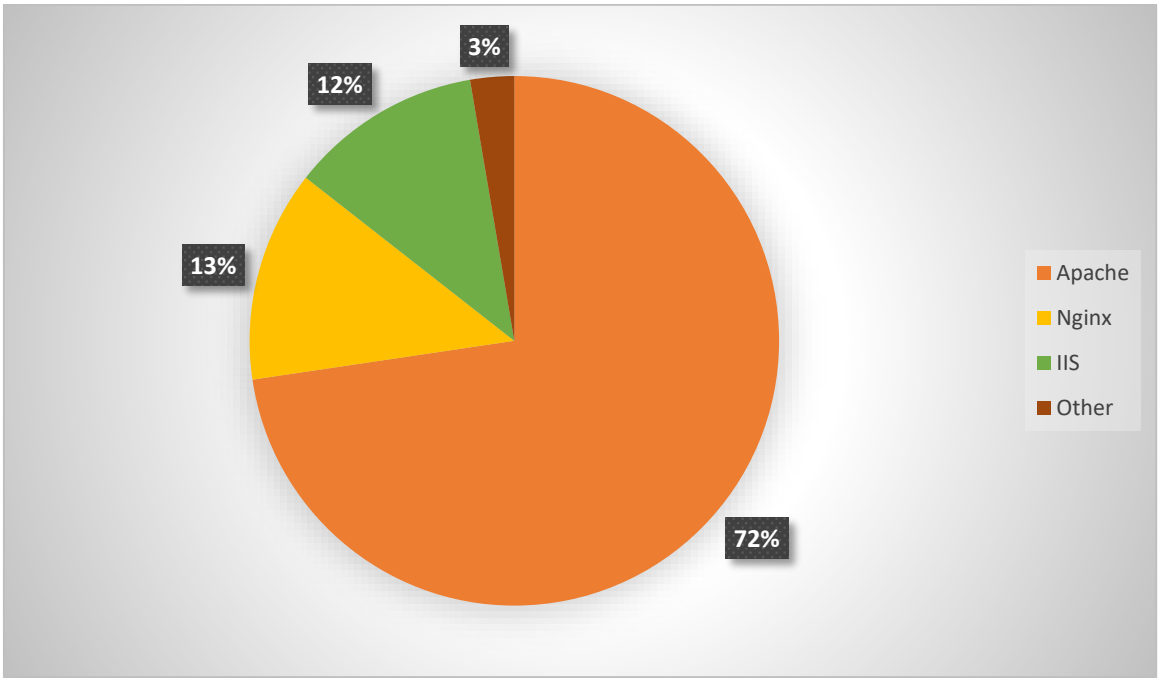


Chart 1 – Attacked resource ratio by web server

Chart 2 provides the breakdown of attacked resources deployed using IIS web servers. As seen from the chart, the most popular versions are 6.0, 7.5 and 8.5. This can be explained by the fact that each version is released as a component of a Windows operating system. For example, version 6.0 was included in Windows Server 2003, version 7.5 was part of Windows 7 and Windows Server 2008, and version 8.5 was included in Windows 8.1 and Windows Server 2012 R2.

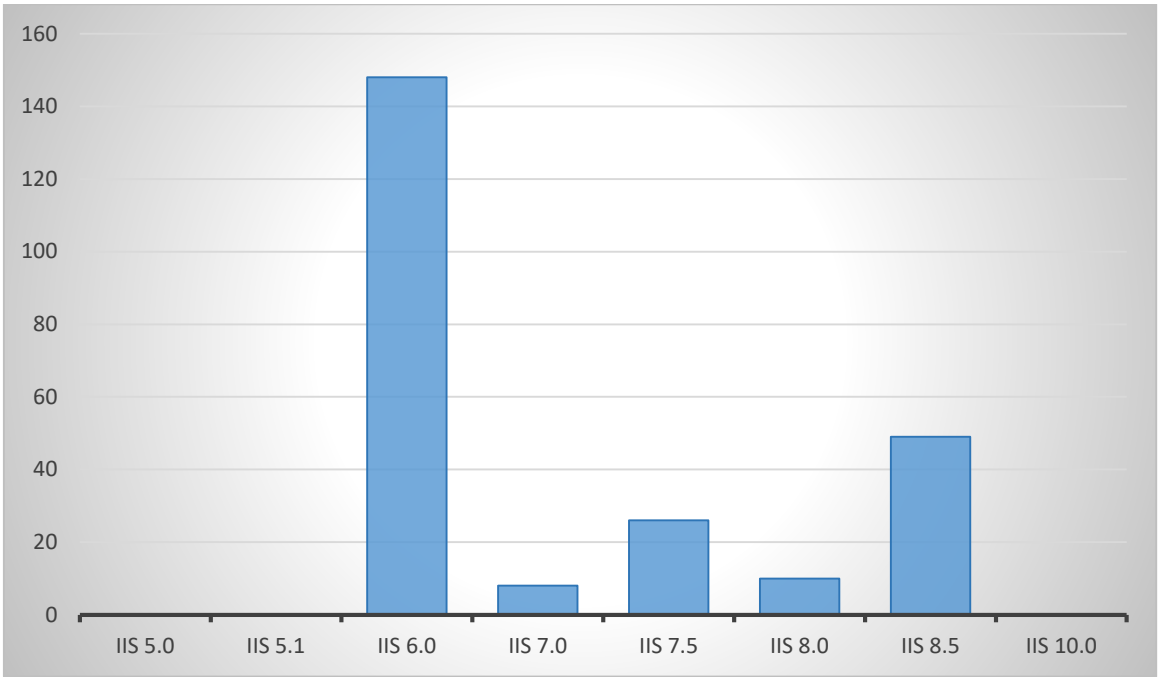


Chart 2 – Attacked resource ratio by IIS version installed

Over a third of all attacked resources were created based on content management systems (CMS). Chart 3 provides the breakdown of attacked resources by CMS used. A high percentage of CMS WordPress can be explained by the fact that in early February researchers discovered a serious CMS WordPress serious CMS WordPress vulnerability, which allows attackers to covertly raise their privileges using REST API. Hackers reportedly attacked around 2 million resources based on WordPress versions 4.7.0 and 4.7.1.

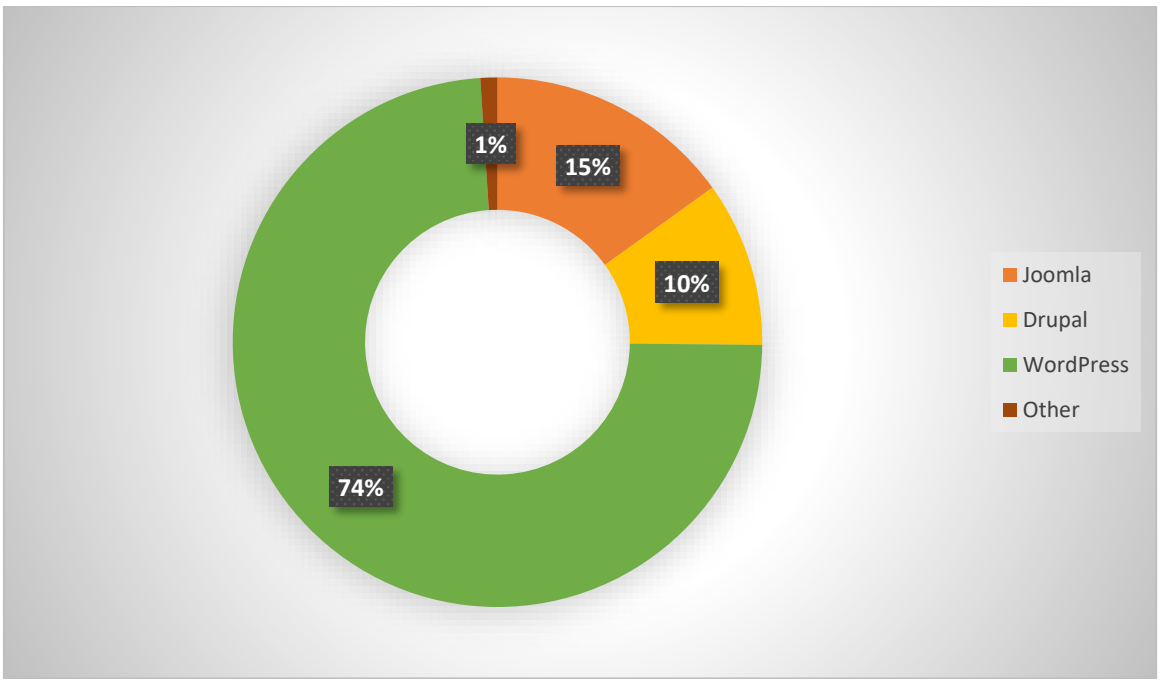


Chart 3 – Breakdown of attacked resources by CMS

Group-IB specialists also managed to identify a CMS version used on some attacked resources.
Chart 4 provides percentage ratio of the latest and outdated CMS versions installed on the attacked resources. The statistics do not include resources, whose CMS versions have not been identified.

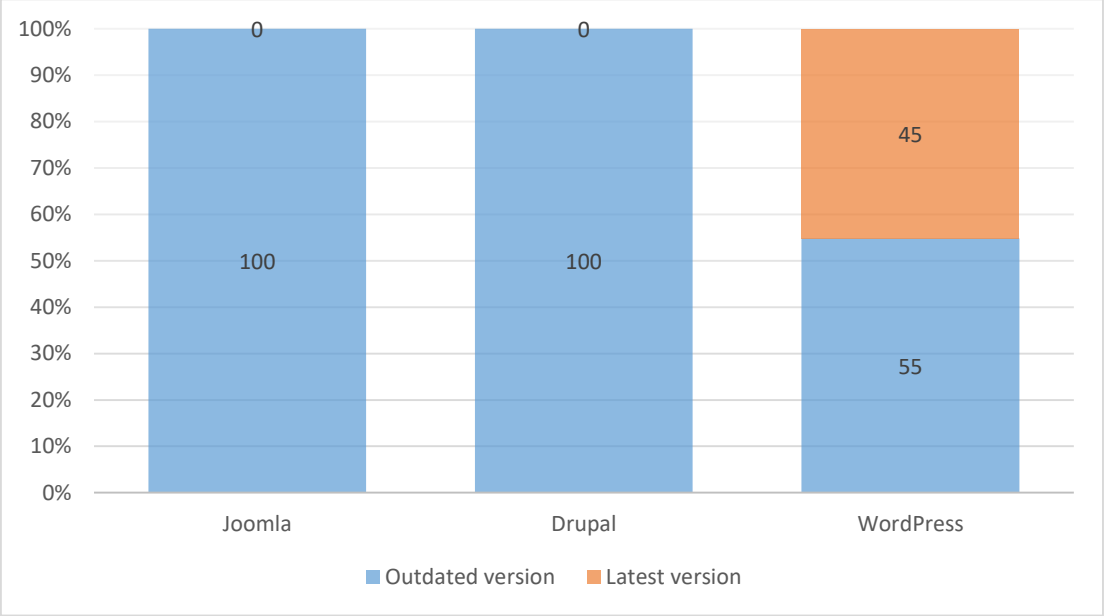


Chart 4 – Percentage ratio of CMS new versions and outdated versions on attacked resources

These statistics clearly indicate that deploying authorized software updates in a timely manner provides protection against various attacks.

Data leakage

- On March 7, 2017 WikiLeaks started publishing a series of documents code-named Vault 7, which are believed to have been obtained as a result of the 'largest ever' leak in the US Central Intelligence Agency (CIA). These dumps detail activities and capabilities of the CIA to perform electronic surveillance and cyber warfare. WikiLeaks claimed that the files had "circulated among former U.S. government hackers and contractors in an unauthorized manner, one of whom has provided WikiLeaks with portions of the archive". The first batch of documents named "Year Zero" consists of 8,761 documents and files, purportedly from an isolated, high-security network situated inside the CIA's Center for Cyber Intelligence.
- The second batch of documents, published on March 23 under the title Dark Matter, reveals exploits that the CIA created to infect Apple devices (Mac, iPhone) with sustainable malware. In addition to that, these documents outline other techniques to attack MacOS devices.
- On January 12, Shadow Brokers posted a final part of their collection sourced from the Equation Group (see Notification DL-1461-3). Based on dump analysis, this part does not contain source codes, unpatched 0day exploits, or full RAT toolsets. The leak reveals codes written in 2003-2012, which cannot be used in attacks on modern operating systems. It also contains binaries of implants that can be employed by cyber-criminals only after reverse analysis. Based on these details, Group-IB specialists believe that this archive poses little threat to governments.